Insper

Roteiro 3

Tecnologias Hackers — Rodolfo Avelino

Investigação de segurança em aplicações web: HTTP, sessões e controle de acesso com Burp Suite

Objetivo da Atividade

Este roteiro tem como objetivo orientar os alunos na realização de testes de segurança em aplicações web, utilizando o Burp Suite para interceptar, observar, modificar e analisar requisições e respostas HTTP.

A atividade propõe investigar como aplicações web implementam mecanismos de autenticação, gerenciamento de sessões e controle de acesso, permitindo que os estudantes compreendam a relação entre as informações enviadas pelo cliente e as decisões de segurança tomadas pelo servidor.

Por meio desta atividade, cada aluno deverá:

1. Compreender o funcionamento das requisições e respostas HTTP, identificando métodos, parâmetros, cabeçalhos, cookies e códigos de resposta.
2. Configurar e utilizar um proxy de interceptação para observar e modificar comunicações entre navegador e aplicação.
3. Investigar como a aplicação mantém sessões autenticadas e quais informações são utilizadas nesse processo.
4. Analisar mecanismos de autorização, verificando como a aplicação controla o acesso a recursos e funcionalidades.

5. Formular hipóteses de segurança e validá-las por meio de testes positivos e negativos.
6. Documentar evidências, diferenciando comportamentos esperados, configurações inadequadas e vulnerabilidades confirmadas.

Ao final, espera-se que o aluno consiga demonstrar como uma requisição HTTP pode ser utilizada para investigar o comportamento de segurança de uma aplicação, apresentando conclusões fundamentadas nas evidências obtidas.

1. Preparação do ambiente

A atividade será realizada individualmente. Cada aluno deverá utilizar sua máquina virtual Kali Linux, previamente preparada para a disciplina, como ambiente de execução de todos os componentes do laboratório, incluindo a aplicação vulnerável, o Burp Suite e o navegador web.

1. **Kali Linux:** máquina virtual que será utilizada como ambiente único de execução do laboratório.
2. **Aplicação web vulnerável:** uma instância local do OWASP WebGoat, executada em container Docker dentro do Kali Linux e utilizada exclusivamente como alvo dos testes.
3. **Burp Suite Community Edition:** ferramenta para interceptação, inspeção e modificação de requisições HTTP.
4. **Navegador web:** configurado para utilizar o proxy do Burp Suite. Recomenda-se o navegador integrado do próprio Burp (**Proxy → Open browser**), que já vem configurado para o proxy.

Insper

O OWASP WebGoat deverá ser executado em um container Docker dentro da máquina virtual Kali Linux. Por se tratar de uma aplicação intencionalmente vulnerável, suas portas deverão ser publicadas exclusivamente na interface de loopback (127.0.0.1), impedindo o acesso direto a partir de outras máquinas da rede.

Para iniciar o ambiente, utilize o comando a seguir:

```
sudo docker run -d \
  --name webgoat-lab \
  -p 127.0.0.1:8080:8080 \
  -p 127.0.0.1:9090:9090 \
  -e TZ=America/Sao_Paulo \
  webgoat/webgoat:v2025.3
```

Versão do ambiente: para garantir maior uniformidade dos testes, todos os alunos deverão utilizar a imagem Docker webgoat/webgoat:v2025.3. A utilização de uma versão específica evita diferenças decorrentes de atualizações posteriores da aplicação, que podem modificar a organização das lições e os comportamentos observados.

Nessa configuração, o WebGoat estará disponível em http://127.0.0.1:8080/WebGoat. A porta 9090 é utilizada pelo WebWolf, componente auxiliar empregado em algumas lições.

Após iniciar o container, verifique sua execução com sudo docker ps e confirme o acesso à aplicação utilizando o navegador integrado do Burp Suite.

Caso a aplicação ainda não esteja disponível, aguarde sua inicialização e consulte os registros com sudo docker logs webgoat-lab.

Insper

Atenção: dependendo da configuração, alguns navegadores podem ignorar o proxy para conexões destinadas a localhost ou 127.0.0.1, impedindo que essas requisições apareçam no Burp Suite. Recomenda-se utilizar o navegador integrado do Burp, que já possui o proxy configurado. Caso seja utilizado o Firefox, verifique as configurações de proxy e, se necessário, habilite network.proxy.allow_hijacking_localhost em about:config.

Antes de iniciar os testes, o aluno deverá verificar se:

- a aplicação está acessível a partir do Kali;
- o navegador consegue estabelecer comunicação com a aplicação;
- o Burp Suite consegue interceptar as requisições;
- as requisições podem ser encaminhadas ao servidor e suas respostas observadas.

Todos os testes deverão permanecer restritos à máquina virtual Kali do próprio aluno.

Registro das evidências: durante a atividade, salve as requisições e respostas relevantes, pois o histórico de uma sessão temporária do Burp Suite não deve ser considerado um repositório permanente de evidências. Utilize a opção de salvar o item ou copie seu conteúdo para um arquivo, identificando cada evidência de forma que possa ser relacionada aos testes realizados e às conclusões apresentadas no relatório.

2. Observação da comunicação HTTP

Nesta etapa, o aluno deverá utilizar o Burp Suite para observar a comunicação entre o navegador e a aplicação.

Insper

2.1. Interceptação de requisições

Acesse a aplicação pelo navegador configurado para utilizar o proxy.

Utilize o recurso **Proxy** → **Intercept** para capturar uma requisição HTTP. Por padrão, o Intercept captura apenas as requisições. O código de resposta e o conteúdo retornado podem ser observados no **HTTP history** ou no **Repeater**.

Após interceptar uma requisição, utilize a opção Forward para encaminhá-la ao servidor ou desative a interceptação para permitir a navegação normal. Em seguida, localize a requisição e sua respectiva resposta no HTTP history.

Identifique:

- método HTTP utilizado;
- caminho do recurso solicitado;
- cabeçalhos enviados;
- parâmetros presentes;
- cookies, quando existentes;
- código de resposta;
- conteúdo retornado pelo servidor.

Utilize também o **HTTP history** para observar a sequência de requisições produzidas durante a navegação.

2.2. Análise

Escolha duas requisições relacionadas a funcionalidades diferentes da aplicação.

Insper

Compare-as e explique quais informações permitem compreender a finalidade de cada requisição.

Investigue quais informações são fornecidas pelo navegador e quais decisões dependem do servidor.

Questão para análise: por que uma aplicação não deve confiar automaticamente nos parâmetros e cabeçalhos enviados pelo cliente?

3. Investigação de autenticação e sessões

Nesta etapa, o aluno deverá investigar como a aplicação estabelece e mantém uma sessão autenticada.

3.1. Autenticação

Realize uma autenticação utilizando uma conta fictícia, criada por você na tela de registro do WebGoat.

Observe, no Burp Suite, as requisições e respostas relacionadas ao processo.

Identifique as diferenças entre a comunicação realizada antes e depois da autenticação. Observe se a aplicação utiliza um identificador de sessão antes do login e se esse identificador é renovado após a autenticação. Explique a importância desse mecanismo para a prevenção de ataques de fixação de sessão (session fixation). Caso o identificador permaneça inalterado, discuta quais verificações adicionais seriam necessárias antes de concluir que existe uma vulnerabilidade.

Insper

3.2. Gerenciamento de sessão

Investigue como a aplicação mantém o contexto de autenticação nas requisições seguintes.

Observe a presença de cookies ou outros mecanismos utilizados pela aplicação, assim como os atributos definidos para eles (por exemplo, HttpOnly, Secure e SameSite).

Utilize o **Repeater** do Burp Suite para repetir uma requisição relacionada a uma funcionalidade autenticada.

Compare o comportamento da aplicação nas seguintes condições:

1. Requisição original, com a sessão autenticada.
2. Requisição sem o identificador de sessão.
3. Requisição após o encerramento da sessão (logout), reenviando o identificador de sessão anterior, quando aplicável.

Registrar as diferenças observadas e explicar o que elas indicam sobre o mecanismo de gerenciamento de sessão.

Lições sugeridas para esta etapa: Hijack a session e Spoofing an Authentication Cookie, na categoria Broken Access Control. Os nomes e a organização das lições podem variar conforme a versão do WebGoat.

Os testes relacionados ao login e ao encerramento da sessão deverão considerar inicialmente o mecanismo de autenticação da própria aplicação WebGoat. As lições

Insper

sugeridas apresentam cenários específicos e poderão utilizar mecanismos de autenticação e sessão diferentes daqueles utilizados pela aplicação principal.

Questão para análise: quais evidências permitem afirmar que determinada requisição foi processada no contexto de uma sessão autenticada?

4. Investigação de controle de acesso

Nesta etapa, o aluno deverá investigar a diferença entre **autenticação e autorização**.

A autenticação permite estabelecer a identidade de um usuário. A autorização determina quais recursos e operações aquela identidade pode acessar.

4.1. Seleção dos recursos

Utilizando as lições do WebGoat, identifique recursos ou operações sujeitos a algum controle de acesso. **Lições sugeridas:** Insecure Direct Object References e Missing Function Level Access Control.

Quando o exercício permitir, utilize duas identidades com permissões ou recursos distintos. Observe que dois usuários registrados no WebGoat têm as mesmas permissões; os cenários de controle de acesso estão dentro das lições, algumas das quais fornecem usuários próprios.

Antes de realizar os testes, identifique a regra de acesso apresentada no cenário da aplicação. A partir dela, estabeleça quais operações deveriam ser permitidas ou negadas para cada identidade, considerando os recursos e as funcionalidades disponíveis.

Insper

4.2. Testes de autorização

Utilize o Burp Suite Repeater para repetir e modificar requisições relacionadas aos recursos selecionados.

Investigue, conforme as funcionalidades disponíveis:

- comportamento de uma requisição sem autenticação;
- acesso a um recurso pelo usuário autorizado;
- tentativa de acesso ao mesmo recurso por outra identidade;
- efeito da alteração de identificadores ou parâmetros relacionados ao recurso.

Para cada teste, registre o comportamento esperado e o resultado efetivamente observado.

Não será suficiente concluir que existe uma vulnerabilidade apenas porque a aplicação retornou um código HTTP diferente.

O aluno deverá examinar também o conteúdo da resposta e verificar se a operação ou o acesso indevido realmente ocorreu.

Questão para análise: uma aplicação pode autenticar corretamente um usuário e ainda apresentar uma vulnerabilidade de autorização? Demonstre a resposta utilizando evidências do laboratório.

5. Construção de uma matriz de testes

A partir das investigações anteriores, o aluno deverá construir uma matriz que consolide os testes realizados nas etapas 3 e 4, relacionando identidades, recursos,

operações e resultados esperados. Não é necessário repetir testes já realizados, desde que estejam registrados na matriz.

A matriz deverá contemplar pelo menos:

- uma operação que deve ser permitida;
- uma operação que deve ser negada;
- uma situação sem autenticação;
- uma situação envolvendo a alteração de um parâmetro ou identificador.

Para cada situação, o aluno deverá comparar o resultado esperado com o comportamento efetivamente observado.

Caso o comportamento seja diferente do esperado, investigue se existe uma falha de segurança ou outra explicação possível.

Sugere-se a seguinte estrutura para a matriz:

Identidade / sessão	Recurso ou endpoint	Operação	Resultado esperado	Resultado observado	Evidência	Classificação

Na coluna Evidência, indique a requisição e a resposta salvas que sustentam o resultado. Na coluna Classificação, indique se o resultado corresponde a um comportamento esperado, a uma configuração inadequada, a uma vulnerabilidade confirmada ou a um resultado inconclusivo. A confirmação de uma vulnerabilidade deverá estar sustentada por evidências de que o controle de segurança foi efetivamente violado.

Insper

O objetivo não é produzir a maior quantidade de testes, mas demonstrar que os testes selecionados permitem avaliar efetivamente uma regra de segurança.

6. Investigação de um comportamento de segurança

Cada aluno deverá selecionar uma situação observada durante as etapas anteriores para realizar uma investigação mais aprofundada. Lições como Authentication Bypasses e JWT tokens também podem servir de ponto de partida.

A situação poderá envolver:

- gerenciamento inadequado de sessão;
- ausência ou inconsistência de controle de acesso;
- tratamento inadequado de parâmetros;
- exposição indevida de informações;
- outro comportamento relevante identificado durante os testes.

A investigação deverá apresentar:

1. **Hipótese:** qual comportamento será investigado e por quê.
2. **Metodologia:** quais requisições serão utilizadas e quais alterações serão realizadas.
3. **Resultado esperado:** qual comportamento indicaria que o controle de segurança está funcionando corretamente.
4. **Evidência:** quais respostas e resultados foram efetivamente observados.
5. **Conclusão:** o que os resultados permitem afirmar, classificando o comportamento como esperado, configuração inadequada, vulnerabilidade confirmada ou resultado inconclusivo.

6. **Recomendação:** como o comportamento poderia ser corrigido ou o controle de segurança aprimorado, quando aplicável.

O aluno deverá demonstrar a relação entre a alteração realizada na requisição e o comportamento observado na aplicação.

Uma hipótese que não seja confirmada também poderá ser apresentada, desde que a investigação tenha sido tecnicamente adequada e suas limitações estejam claras.

7. Entregáveis

Cada aluno deverá entregar:

7.1. Relatório técnico

O relatório deverá apresentar:

- descrição do ambiente utilizado;
- metodologia dos testes;
- análise das requisições e respostas HTTP;
- investigação dos mecanismos de sessão;
- matriz de testes de autenticação, sessão e autorização;
- investigação aprofundada de um comportamento de segurança;
- evidências e conclusões;
- recomendações, quando aplicáveis.

As evidências poderão incluir requisições e respostas salvas do Burp Suite, acompanhadas de explicações técnicas.

Insper

Não será necessário apresentar capturas de tela de todos os passos realizados. As evidências selecionadas deverão sustentar as conclusões.

7.2. Demonstração prática

O aluno deverá demonstrar, no ambiente preparado em sua máquina virtual kali:

1. A interceptação de uma requisição HTTP.
2. A utilização do Repeater para modificar ou repetir uma requisição.
3. A execução de um teste relacionado à autenticação, sessão ou autorização.
4. A explicação do resultado observado e das evidências que sustentam a conclusão.

Durante a demonstração, o professor poderá solicitar a alteração de uma condição do teste para verificar a compreensão do aluno sobre o comportamento da aplicação.

8. Critérios de avaliação

Critério	Pontuação
Preparação e funcionamento do ambiente	1,0
Análise das requisições e respostas HTTP	1,5
Investigação de autenticação e sessões	2,0
Testes de autorização e matriz de resultados	2,0
Qualidade da investigação aprofundada (etapa 6), evidências e conclusões	2,0
Relatório técnico	0,75
Demonstração prática	0,75

Insper

Total	**10,0 pontos**

A avaliação considerará principalmente a capacidade do aluno de compreender o funcionamento da aplicação, formular hipóteses, executar testes adequados e sustentar suas conclusões com evidências.

A simples utilização de ferramentas automatizadas ou a identificação de um grande número de vulnerabilidades não será suficiente para obter a pontuação máxima.